Scenario 1 — Attacco Cross-Site Scripting (XSS)

In questo scenario, l'azienda ha ricevuto segnalazioni da utenti che hanno subito un attacco Cross-Site Scripting (XSS) tramite un form online vulnerabile.
L'applicazione non validava correttamente l'input inserito dagli utenti, consentendo l'esecuzione di codice JavaScript malevolo nel browser della vittima; questo ha permesso agli attaccanti di rubare i cookie di sessione e impersonare altri utenti, compromettendo l'integrità e la riservatezza delle sessioni.

Secondo la **classificazione OWASP Top 10**, questa vulnerabilità rientra nella categoria A03:2021 – Injection, che include gli attacchi XSS: questa categoria comprende tutte le vulnerabilità in cui input non validati vengono interpretati come codice eseguibile.
Nel framework MITRE ATT&CK Enterprise, la tecnica principale associata a questo attacco è T1059 – Command and Scripting Interpreter, in quanto l'attaccante utilizza codice JavaScript per eseguire istruzioni nel browser della vittima.
Inoltre, l'attacco comporta il furto delle informazioni di sessione, che può essere associato anche alla tecnica T1539 – Steal Web Session Cookie, utilizzata per impersonare utenti legittimi.

La mitigazione suggerita dal framework MITRE ATT&CK include l'implementazione di controlli di validazione e sanitizzazione dell'input lato server, al fine di impedire l'inserimento di codice malevolo.
È inoltre raccomandato l'utilizzo di meccanismi di protezione come l'escaping dell'output, l'implementazione di Content Security Policy (CSP) e la protezione dei cookie tramite attributi di sicurezza come HttpOnly e Secure, per impedire l'accesso ai cookie da parte di script non autorizzati.

Scenario 2 — Attacco SQL Injection

Nel secondo scenario, un attaccante è riuscito a ottenere accesso non autorizzato ai dati aziendali sfruttando una vulnerabilità SQL Injection presente nell'interfaccia di login dell'applicazione.
Manipolando l'input inserito nei campi di autenticazione, l'attaccante è riuscito a eseguire comandi SQL arbitrari e a estrarre dati sensibili dal database aziendale.
Secondo OWASP Top 10, questa vulnerabilità rientra nella categoria **A03:2021 – Injection**, che include SQL Injection come una delle principali tecniche di attacco; questo tipo di vulnerabilità si verifica quando i dati inseriti dall'utente non vengono correttamente validati o filtrati prima di essere utilizzati nelle query SQL.

Nel framework MITRE ATT&CK Enterprise, la tecnica principale associata è **T1190 – Exploit Public-Facing Application**, che descrive lo sfruttamento di vulnerabilità presenti in applicazioni accessibili pubblicamente per ottenere accesso non autorizzato;inoltre, l'estrazione dei dati può essere associata alla tecnica **T1005 – Data from Local System**, che descrive l'accesso e il furto di dati da sistemi compromessi.

La mitigazione suggerita da MITRE ATT&CK include l'utilizzo di query parametrizzate e prepared statements, che impediscono l'esecuzione di codice SQL arbitrario. È inoltre fondamentale implementare controlli di validazione dell'input, limitare i privilegi degli account database e utilizzare sistemi di monitoraggio per rilevare attività sospette.

Scenario 3 — Esecuzione remota di codice tramite deserializzazione non sicura

Nel terzo scenario, un attaccante è riuscito a eseguire codice arbitrario sul server sfruttando una vulnerabilità di deserializzazione non sicura, l'applicazione accettava oggetti serializzati forniti dall'utente senza verificare la loro integrità o validità; manipolando questi oggetti, l'attaccante è riuscito a eseguire codice remoto sul server, compromettendo il sistema.

Secondo OWASP Top 10, questa vulnerabilità rientra nella categoria **A08:2021 – Software and Data Integrity Failures**, che include vulnerabilità legate alla deserializzazione non sicura e alla mancanza di controlli sull'integrità dei dati.

Nel framework MITRE ATT&CK Enterprise, la tecnica principale associata è **T1203 – Exploitation for Client Execution**, che descrive lo sfruttamento di vulnerabilità software per eseguire codice arbitrario su un sistema target. Inoltre, l'esecuzione di codice remoto può essere associata alla tecnica **T1059 – Command and Scripting Interpreter**, utilizzata per eseguire comandi sul sistema compromesso.

La mitigazione suggerita da MITRE ATT&CK include l'implementazione di controlli di validazione rigorosi sugli oggetti serializzati, evitando di deserializzare dati non affidabili. È inoltre raccomandato utilizzare meccanismi di firma digitale per verificare l'integrità dei dati, limitare i privilegi delle applicazioni e implementare controlli di sicurezza lato server per prevenire l'esecuzione di codice non autorizzato.

Conclusione

Gli scenari analizzati dimostrano come vulnerabilità comuni nelle applicazioni web, come Cross-Site Scripting, SQL Injection e deserializzazione non sicura, possano essere sfruttate per compromettere la sicurezza dei sistemi aziendali.

L'utilizzo dei framework OWASP Top 10 e MITRE ATT&CK consente di classificare queste vulnerabilità e identificare tecniche di attacco e mitigazioni appropriate. L'implementazione di controlli di sicurezza adeguati, come la validazione dell'input, l'utilizzo di query sicure e la verifica dell'integrità dei dati, rappresenta una misura fondamentale per prevenire questi attacchi e proteggere i sistemi aziendali.